Kriptográfia és biztonság 2.

Egy kis történelem

Már a görögök is...

Alapkérdések

- ki mit tud/küld? (kommunikációs modell)
- mi a támadás? (fenyegetés modell)

Egyszerű történelmi példák

- üzenetküldés két fél között
- támadás: az ellenség megszerzi az üzenetet

Már a görögök is...

Skytale

- $c = ?$
- $k = ?$

Skytale, original diagram for Wikipedia created by User:Luringen

Már a görögök is...

Atbash

- héber rejtjel a héber abc-hez
- egyszerű helyettesítés (betűcserék): $\aleph \leftrightarrow tav, \beth \leftrightarrow sin, \ldots$
- latin abc-re:

```
Eredeti:  abcdefghijklmnopqrstuvwxyz
Kódolt:   zyxwvutsrqponmlkjihgfedcba
```

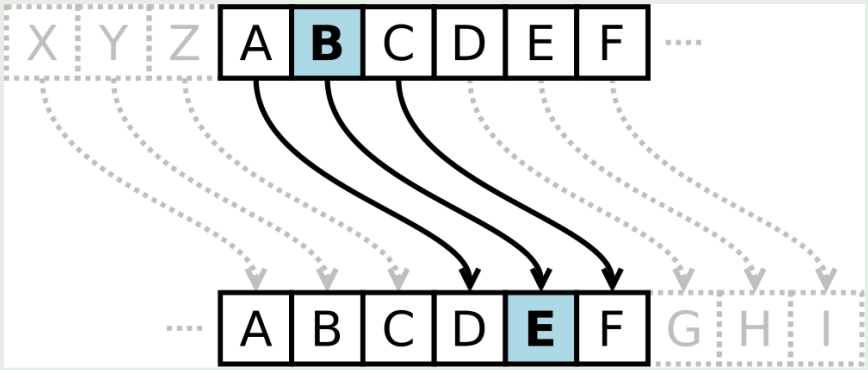
Tulajdonságok

- Ószövetségi példák
- pre-kriptanalízis
- mai szemmel nagyon gyenge (fix permutáció)

Már a görögök is...

Caesar-rejtjel

- minden betűt a 3-al későbbivel helyettesítünk:



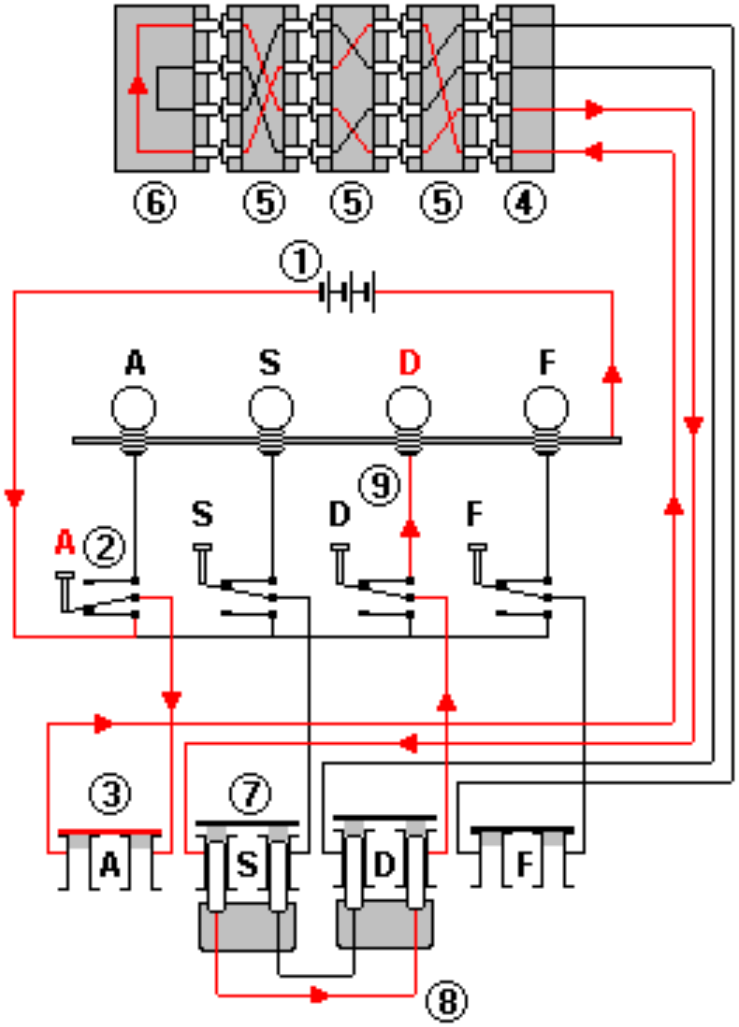
Tulajdonságok

- Julius Ceasar (i.e. 100-44) nevéhez fűződik
- törhető: Al-Kindi (9. sz.)
- 1915-ben az orosz hadsereg még használta
- jelenleg: ROT-13 (fórumokon anti-spoiler)

Hagyományos kriptográfia

19. századtól

- katonai alkalmazás: kommunikáció védelme
- ad-hoc konstrukciók
- törés csak idő kérdése
- igény: formális keretek



Szimmetrikus kulcsú titkosítás (informálisan)

- cél: két résztvevő közötti kommunikáció védelme
- setup: közös titkos kulcs legyártása + megosztása
- m : nyílt szöveg (üzenet), c : titkos szöveg, k : közös kulcs
- három algorimusból áll:
  1. Gen a kulcsgenerálás: k kulcs kiválasztása az összes lehetséges közül valamilyen eloszlás szerint
  2. Enc a titkosítás: adott kulcsból és üzenetből titkos szöveg: $c = Enc_k(m)$
  3. Dec visszafejtés: adott kulcsból és titkos szövegből üzenet: $m = Dec_k(c)$
- kommunikáció:
  - közös kulcs eljuttatása **védett** csatornán
  - a titkos szöveg átküldése **nyílt** csatornán

Kerchkoff-elvek

Titkosítás követelményei (Kerckhoff 1883)

1. ha egy rendszer elméletileg nem feltörhetetlen, akkor gyakorlatilag legyen az
2. ne igényeljen titkosságot, és ne okozzon gondot, ha az ellenséghez kerül
3. a kulcs legyen könnyen megjegyezhető, ne kelljen lejegyezni, és szükség szerint legyen könnyen kicserélhető, megváltoztatható
4. táviratként lehessen továbbítani
5. legyen hordozható, és egyetlen ember is tudja működtetni
6. legyen könnyen kezelhető, ne kelljen hozzá rengeteg szabályt figyelembe venni

"A" Kerchkoff-elv

Titkosítás követelményei (Kerckhoff 1883)

2. ne igényeljen titkosságot, és ne okozzon gondot, ha az ellenséghez kerül

Kulcs vs. eljárás védelme

- biztonságos szétosztás + tárolás
- kompromitált komponensek cseréje
- kommunikáció több résztvevővel

Konklúzió

- cél: kulcs ismerete nélkül, a támadó nehezen tudja visszanyerni az üzenetet
- a jó kripto algoritmus mindig nyilvános!!!
- public domain vs. security by obscurity

Támadók eszköztára

Hagyományos módszerek

- brute-force (összes kulcs kipróbálása)
- gyakoriság elemzés (nyelvek entrópiái)
- egybeesés-számlálás
- protokoll/implementációs hiba kiaknázása

Egyéb módszerek

- reverse-engineering (sec-by-obsc)
- szoftveres/hardveres támadások (DOS/fault attacks)
- side-channel támadások
- **felhasználók elleni támadások** (adathalászat, social engineering)

Támadók eszköztára

Passzív támadások

- titkos szövegű támadás (ciphertext-only attack): egy/több, ugyanazzal a k-val titkosított szöveg ismeretében egy/több üzenet meghatározása
- ismert nyílt szövegű támadás (known-plaintext attack): egy/több nyílt-titkos szöveg pár ismeretében további üzenetek meghatározása a megfelelő titkos szövegből (k ugyanaz!)

Támadók eszköztára

Aktív támadások

- választott nyílt szövegű támadás (chosen-plaintext attack): a támadó által választott egy/több üzenetnek ugyanazzal a k-val titkosított titkos szövegének ismeretében egy üzenet meghatározása
- választott titkos szövegű támadás (chosen-ciphertext attack): a támadó által választott egy/több titkos szövegnek ugyanazzal a k-val visszafejtett nyílt szövegének ismeretében egy üzenet meghatározása a titkos szövegből (aminek a visszafejtése nem ismert)

Támadók eszköztára

Hagyományos titkosítási példák

Eltolásos rejtjel

- elv: minden betűt ugyanazzal a véletlen értékkel eltolunk
- angol abc betűit $0, 1, 2, \ldots, 25$ számokra kódoljuk

Eltolásos rejtjel

1. $Gen : k \in \{0, 1, \ldots, 25\}$ véletlenül választva
2. Enc : karakterenként: $c_i = Enc_k(m_i) \equiv m_i + k \pmod{26}$
3. Dec : karakterenként: $m_i = Dec_k(c_i) \equiv c_i - k \pmod{26}$

Példa: $m = \texttt{EXAMPLE} \rightarrow (4, 23, 0, 12, 15, 11, 4)$

1. $Gen : k = 11$
2. $Enc : c = (15, 8, 11, 23, 0, 22, 15) \rightarrow \texttt{PILXAWP}$
3. $Dec : m = (4, 23, 0, 12, 15, 11, 4) \rightarrow \texttt{EXAMPLE}$

Hagyományos titkosítási példák

Eltolásos rejtjel

1. $Gen : k \in \{0, 1, \ldots, 25\}$ véletlenül választva
2. Enc : karakterenként: $c_i = Enc_k(m_i) \equiv m_i + k \pmod{26}$
3. Dec : karakterenként: $m_i = Dec_k(c_i) \equiv c_i - k \pmod{26}$

Tulajdonságok

- triviálisan törhető: kipróbáljuk mind a 26 lehetséges kulcsot (brute-force)
- következmény: nagy kulcstér
- biztonság szükséges feltétele (de nem elégséges...)
- pl: 128 hosszú bitsorozatok ($= 2^{128}$ db kulcs)

Hagyományos titkosítási példák

Mono-alfabetikus helyettesítés

- elv: minden betűt bijekcióval ugyanabból az abc-ből (pl. az angolból) vett másik betűre cserélünk
- kulcstér: az abc elemeinek összes permutációi

Mono-alfabetikus helyettesítés

1. $Gen : k$ permutáció 26 elemen véletlenül választva
2. Enc, Dec : betűnként használjuk a permutációt/inverzét

Példa: $m = \texttt{PERMUTATION}$

1. $Gen : k = \begin{array}{l} \texttt{ABCDEFGHIJKLMNOPQRSTUVWXYZ} \\ \texttt{xeuadnbkvmrocqfsyhwglzijpt} \end{array}$
2. $Enc : c = \texttt{sdhclgxgvfq}, Dec : m = \texttt{PERMUTATION}$

Hagyományos titkosítási példák

Mono-alfabetikus helyettesítés

1. $Gen : k$ permutáció 26 elemen véletlenül választva
2. Enc, Dec : betűnként használjuk a permutációt/inverzét

Tulajdonságok

- kulcstér: $26! \approx 2^{88}$ elég nagy, de...
- betűnként fix $\Rightarrow$ statisztikai támadás a nyelv mintái alapján
- gyakoriságelemzés: betűk eloszlása ismert, rövid szöveg (10 szavas) már elég közel van az átlaghoz
- néhány betű könnyen azonosítható, a maradék brute-force
- nehezen automatizálható
- csak "értelmes" szöveg esetén működik

Hagyományos titkosítási példák

Vigenère rejtjel

- elv: betű-eloszlások elkenése
- ugyanazt a betűt különböző helyen különböző mértékben toljuk el (poli-alfabetikus eltolás)

Poli-alfabetikus eltolás

1. $Gen : k = (k_1, \ldots, k_t)$ random sorozat (t nem fix)
2. $Enc : c_{i+jt} \equiv m_{i+jt} + k_i \pmod{26} : i = 1, \ldots, t, j = 0, \ldots$
3. $Dec : m_{i+jt} \equiv c_{i+jt} - k_i \pmod{26} : i = 1, \ldots, t, j = 0, \ldots$

Példa: $m = \texttt{THISISIMPOSSIBLE}$

1. $Gen : k = false$
2. $Enc : \begin{array}{rl} m = & \texttt{THISISIMPOSSIBLE} \\ k = & \texttt{falsefalsefalsef} \\ c = & \texttt{YHTIMXIXHSXSTTPJ} \end{array}$

Hagyományos titkosítási példák

Poli-alfabetikus eltolás

1. $Gen : k = (k_1, \ldots, k_t)$ random sorozat (t nem fix)
2. $Enc : c_{i+jt} \equiv m_{i+jt} + k_i \pmod{26} : i = 1, \ldots, t, j = 0, \ldots$
3. $Dec : m_{i+jt} \equiv c_{i+jt} - k_i \pmod{26} : i = 1, \ldots, t, j = 0, \ldots$

Tulajdonságok

- ha t ismert $\Rightarrow$ törhető (t-hosszú ciklusok + statisztika)
- Kasiski módszere: 2,3 hosszú ismétlődések keresése, ezek távolsága t többszöröse $\Rightarrow t =$ ezek lnko-ja
- egybeesés-számlálás: $c_1, c_{k+1}, c_{2k+1}, \ldots$-ra statisztika $\Rightarrow$ hosszú szöveg és rövid kulcs esetés könnyű
- Példa: amerikai polgárháború alatt a konföderációs erőknél ($k = \texttt{completevictory} \Rightarrow$ sima törés...)

Ma is tanultam valamit

Összegzés

- Kerchkhoff-elv: kriptorendszer legyen nyilvános
- Gyakorlatban végigpróbálhatatlan kulcstér
- Biztonságos kriptorendszer kidolgozása nehéz
- Ad-hoc konstrukciók helyett valami több kell